

Protect Your Network

When implemented properly, an intrusion detection device can provide a powerful and cost-effective solution that complements a firewall in protecting your corporate assets

The landscape of doing business today is significantly different from the landscape of just five years ago. Companies are more connected than ever, with the promise that network expansion will only continue. As a result, companies must grapple with how to keep their network safe, without sacrificing growth or productivity.

Intrusion Detection And Prevention Must Operate In Line

Most of the NIDS (Network Intrusion Detection System) products on the market are unable to prevent attacks because they are “passive,” sniffer-based intrusion detection systems. These systems can only “listen” to the traffic. They cannot control the traffic, by either dropping, modifying, steering or delaying packets or by injecting their own packets into the network, when appropriate. It is easy to understand why most NIDSes operate as passive devices. Any intervention with the flow of packets may be dangerous if you can’t trust the results of the attack identification. To date, the results of current NIDSes are hampered by false positives and inaccurate attack identification, due to a reliance on single, poorly implemented methods of detection. However, if an NIDS can demonstrate accurate results, it is important to under-

stand why it needs to operate in-line to provide complete protection.

Preventing Evasion

Passive intrusion detection systems will always be vulnerable to evasion techniques. This is due to the fact that passive network monitoring enables traffic ambiguity, making it very difficult to ever provide a reliable intrusion detection mechanism. This section will explain the basics of evading intrusion detection systems; how it is being done in practice and why it is always possible to evade passive intrusion detection systems. After reading this section it will be clear that the only way to stop evasion is to operate an intrusion detection system as an in-line device to eliminate traffic ambiguity.

Evading Intrusion Detection Systems: The Theory

The basic idea behind evasion is to fool the intrusion detection mechanism into “seeing” different data than the target host, often referred to as the “victim.” This allows an attacker to attack the host

without being detected. This applies to both signature-based and protocol anomaly-based intrusion detection systems.

To understand the idea, you first need to understand how an NIDS performs TCP reassembly. Application 1 generates information for communication as a stream of data (MESSAGE). The operating system breaks that stream into segments (“TCP segments”) and sends them to the network. The receiving operation system collects the TCP segments and converts them back to a stream of data (MESSAGE), which is then presented to the receiving application. Since the underlying network does not guarantee delivery of the TCP segments, the receiver tells the sender which segments have and have not been received. The sender can then retransmit the missing segments.

TCP reassembly, in the context of NIDS, is the process of collecting TCP segments in the order that the sending application sent them and extracting the application data stream from them. When performing TCP reassembly as a passive system, it is easy to look at each and every TCP segment (packet), but it very difficult to perform the TCP reassembly in a manner that is consistent with what the receiver would “see.”

Upon receiving a TCP segment, the NIDS sensor needs to decide what to do with it. There are several handling options for the receiver of the TCP segments:

1. *Use the entire segment*—this is the most common scenario
 2. *Use part of the segment for TCP reassembly, while ignoring the rest of it*—this happens when the segment overlaps another segment that has already been received, or if part of the segment is beyond the window (sequence number of packets that the receiver is anticipating) and is, therefore, ignored.
 3. *Ignore the segment completely*—this happens if the segment was received before or is invalid. Invalid packets include those that have incorrect IP or TCP checksums, invalid TCP flags, old TCP timestamps, as well as many other situations.
 4. *Did not receive the segment*—The receiver might not even receive the TCP segment because of network issues (the segment might disappear) or packet settings (such as IP TTL).
- The NIDS sensor must figure out how the intended receiver will handle the TCP segment and handle it exactly the same way. If the NIDS makes the wrong decision:

The NIDS sensor will use a segment that the receiver will not, thus seeing data that the receiver will ignore. The NIDS sensor will ignore a segment that the receiver will use, thus missing data. In both cases, the NIDS sensor will be running its checks (either signature matching or protocol anomaly detection) on the wrong data.

Evasion In Practice

Now that the basics of NIDS TCP reassembly are understood, the problem of NIDS evasion can be restated:

NIDS evasion happens when an NIDS sensor makes a mistake in using or not using a part or an entire TCP segment for TCP reassembly. Such a mistake will make the NIDS see different data than the sender and receiver of the TCP flow.

In practice, to evade the NIDS sensors, the attacker constructs TCP segments that make it virtually impossible for the NIDS to determine whether or not the “victim” will accept them. If the victim does accept them, it is impossible for the NIDS to determine which portion of the segments it would use. Such TCP segments are referred to as “ambiguous TCP segments.”

The attacker then retransmits the same TCP segment with different data, triggering either one of the following scenarios:

The NIDS sensor used the original dummy TCP segment in its reassembly and the victim has dropped it. The second TCP segment, which contains the attack, is ignored by the NIDS sensor (since it has already seen that segment before) and used by the victim (since it ignored the previous one); or

The NIDS sensor ignored the original attacking TCP segment in its reassembly, while the victim used it. The second TCP segment, which is a dummy, is accepted by the NIDS sensor and ignored by the victim.

Constructing Ambiguous TCP Segments

This section presents several different methods for constructing ambiguous TCP segments. While some of these methods may have a way for an NIDS to deal with them, most do not have a theoretical algorithm that would enable an NIDS to determine what the victim will do with the TCP segments.

Effortless Construction Of Ambiguous TCP Segments

There exist some very simple techniques to create ambiguous TCP segments. A good NIDS must be able to eliminate these ambiguities in order to properly interpret the traffic being transmitted. The techniques to create ambiguous segments are:

Invalid TCP checksums—the victim will certainly drop a packet with an invalid TCP checksum. An NIDS that fails to validate the TCP checksum will be accepting packets that are dropped by the victim.

Out-of-window data—a receiver only accepts data within a certain window, called the “receiver window.” The receiver will ignore data out this window. However, not being the actual receiver, it is very difficult for an NIDS that’s performing a passive reassembly to determine



The basic idea behind evasion is to fool the intrusion detection mechanism into “seeing” different data than the target host